

MÁSTER EN *ANÁLISIS DE MALWARE Y REVERSING*



Campus Internacional
CIBERSEGURIDAD

ENIIT
INNOVA IT BUSINESS SCHOOL



UCAM
UNIVERSIDAD
CATOLICA DE MURCIA

ÍNDICE DE CONTENIDOS

1. ACTIVIDADES INDIVIDUALES	3
1.1. Manejo de estructuras y funciones del kernel en un Rootkit de Windows 11	4
1.1.1. Enunciado	4
1.1.1.1. Desarrollo de un Rootkit avanzado para Windows 11	4
1.1.1.2. Mecanismos de protección de Microsoft	4
1.1.2. Actividad	5
1.1.2.1. Driver de Modo Kernel	5
1.1.3. Entregables	6
1.1.4. Recursos	7
1.1.5. Consideraciones	8
2. NOTAS	9

1. ACTIVIDADES INDIVIDUALES

Antes de llevar a cabo la actividad individual que aquí se plantea, es recomendable haber indagado en los cinco primeros temas, y a mayores como ejercicio auxiliar, que cada alumno según su interés y conocimiento en la materia, profundice en las operaciones y funcionamiento interno de algún driver que sea extensamente conocido, ya que esto ayudará a comprender mejor las estructuras y llamadas a funciones del kernel, facilitando el adentrarse en el reversing del sistema operativo.

Como ejemplo, y analizando un caso ya comentado durante el módulo, se dejan los siguientes recursos sobre el driver de la herramienta mimikatz (mimidrv.sys) a modo de consulta inicial para esta actividad:

- [Github: mimidrv.sys](#)
- [Blog: Mimidrv In Depth](#)
- [Blog: Detecting PPL Manipulation](#)
- [Blog: Disabling LSASS protection with mimidrv.sys](#)
- [Web CodeMachine: Windows kernel data structures](#)

1.1. MANEJO DE ESTRUCTURAS Y FUNCIONES DEL KERNEL EN UN ROOTKIT DE WINDOWS 11

1.1.1. ENUNCIADO

1.1.1.1. DESARROLLO DE UN ROOTKIT AVANZADO PARA WINDOWS 11

Mike, un experto en ciberseguridad y desarrollador de malware, que actualmente forma parte de un equipo de Red Team, se encuentra en una operación muy compleja que requiere la implementación e instalación de uno de los tipos de malware más dañinos en cuanto a sus capacidades de persistencia y control, un Rootkit.

Como es habitual, una empresa internacional, en este caso CompuSec S.L., ha contratado los servicios de la compañía para la que Mike trabaja, requiriendo de los conocimientos del equipo, con el objetivo concreto de intentar evadir los mecanismos de protección existentes en las estaciones de trabajo y servidores.

La mayor preocupación de la empresa y la razón detrás de esta operación es el temor, inherente a su sector, de ser víctima de un espionaje indetectable en sus sistemas que pudiese conducir al robo de proyectos altamente confidenciales.

El equipo lleva a cabo la planificación de varias campañas de phishing, muy dirigidas, para instalar el rootkit de forma remota en sistemas específicos y, así, obtener un acceso indetectable y control completo del sistema operativo.

1.1.1.2. MECANISMOS DE PROTECCIÓN DE MICROSOFT

Tras un minucioso análisis a partir de los datos obtenidos de un reconocimiento activo sobre la infraestructura de CompuSec S.L., se llega a la preocupante conclusión de que una gran cantidad de equipos no tienen habilitada la función de Secure Boot (barrera fundamental para prevenir la ejecución de código no autorizado en el arranque del sistema), otros tienen deshabilitada la opción Driver Signature Enforcement (barrera fundamental para prevenir la ejecución de código no autorizado en el kernel del sistema), y en algún caso se ha detectado la existencia de drivers vulnerables.

Estas omisiones en la configuración de seguridad de la BIOS y del propio sistema operativo Windows, plantea un riesgo significativo, ya que habilita la instalación del rootkit por diferentes vías, mediante la explotación de características propias del sistema.

1.1.2. ACTIVIDAD

Este módulo, donde tratamos de explorar de forma completa el concepto de ingeniería inversa en sistemas operativos Windows, se divide en siete áreas que forman parte o están relacionadas con el núcleo de Windows.

En cada uno de los puntos (UEFI, Arranque, Bootkits, Kernel, Protecciones, Debugging y Rootkits), profundizamos de forma técnica, siendo bastante sencillo el ir practicando a la vez que se indaga en el módulo, ya que todos los ejercicios que necesitamos explorar se encuentran en el manual y en los documentos adjuntos.

Esta actividad está pensada para probar el conocimiento adquirido sobre el conjunto de aspectos relacionados con la ejecución de código en ring 0, mediante el desarrollo de drivers de modo kernel en Windows y la existencia de mecanismos de protección.

1.1.2.1. DRIVER DE MODO KERNEL

Como primera aproximación para tomar contacto con todas las posibilidades que nos ofrece el ejecutar código en Ring 0, se propone el desarrollo de un driver de modo kernel que implemente alguna funcionalidad por la que tengáis curiosidad, y que esté relacionada con al menos una determinada estructura del kernel.

Puede ser algo tan básico como llamar a unas funciones que queráis explorar, listar los hilos en ejecución de la máquina y hacer x operación, comprobar los elementos de una estructura y realizar un cambio, ..., o algo más avanzado que pueda ser el inicio de un rootkit o una herramienta de detección.

El objetivo es obtener una metodología y encontrar los recursos necesarios para implementar esa determinada funcionalidad. Por lo que deberéis anotar las fuentes que vayáis consultando durante el proceso, páginas web relevantes, repositorios de github, videos de conferencias, herramientas, chatbots, es decir, todo aquel recurso que os haya servido para comprender y poder desarrollar ese driver.

Naturalmente, se valorará la complejidad de la funcionalidad, pero lo relevante y lo que se tendrá más en cuenta es la explicación técnica del funcionamiento.

Al igual que en los drivers de ejemplo, que encontraréis en el script de configuración de entorno del módulo, tendréis que explicar, con vuestras palabras tal y como vosotros lo entendéis, cada línea de código de forma extensa.

1.1.3. ENTREGABLES

En cuanto a la entrega, deberéis crear un proyecto en github, público o privado, cuya url posteriormente indicaréis, y subir a este, al menos, los siguientes ficheros:

- ***.***: Código fuente del rootkit (driver de modo kernel para windows), acompañado de comentarios sobre las funciones.
- **Readme.md**: Explicación sobre el motivo del proyecto y todas las consideraciones que queráis reflejar.
- **poc.mp4 (opcional)**: Video opcional donde se muestre la ejecución u otros detalles del malware.

1.1.4. RECURSOS

Para llevar a cabo el desarrollo, os podéis apoyar, aparte de en los recursos adicionales del módulo, en los siguientes enlaces:

- Youtube Video: [GuidedHacking - How to make a Kernel Driver](#)
- Youtube Video: [BlackHat 20 - Demystifying Modern Windows Rootkits](#)
- Youtube Video: [BlackHat 20 - The Art of Emulating Kernel Rootkits](#)
- Documentación Microsoft: [Introducción a los drivers en Windows](#)
- Documentación Microsoft: [Guía de diseño para drivers en modo kernel](#)
- Documentación Microsoft: [Estructuras opacas del kernel de Windows](#)
- Web Vergilius: [Estructuras del kernel](#)
- Web Geoff Chappell: [Estructuras del kernel](#)
- Web CyberArk: [Rootkits and Where to Find them 1](#)
- Web CyberArk: [Rootkits and Where to Find them 2](#)
- Web CyberArk: [Rootkits and Where to Find them 3](#)
- Github: [Malware Research](#)
- Github: [Advanced Windows exploit development resources](#)
- Github: [Infosec Reference - Rootkits](#)
- Github: [Awesome Windows Kernel Security Development](#)
- Github: [A kernel-mode rootkit](#)
- Github: [MasterHide is a x64 Windows Driver](#)
- Github: [TitanHide is a driver intended to hide debuggers](#)
- Github: [Windows 10 Kernel-mode rootkit](#)
- Github: [A kernel rootkit with remote command](#)
- Github: [HideProcess](#)
- Github: [Nidhogg is a multi-functional rootkit for red teams](#)
- Github: [Spectre is a Windows kernel-mode rootkit](#)
- Github: [Cronos is Windows 10/11 x64 ring 0 rootkit](#)
- Github: [Black Angel is a Windows 11/10 x64 kernel mode rootkit](#)
- Web RedTeamNotes: [Interrupt Descriptor Table \(IDT\)](#)
- Web RedTeamNotes: [Direct Kernel Object Modification](#)
- Web RedTeamNotes: [System Service Descriptor Table \(SSDT\)](#)

1.1.5. CONSIDERACIONES

El objetivo último de desarrollar un rootkit, es profundizar en el kernel del sistema operativo Windows y todos los elementos/protecciones relacionados. Una vez terminado dicho desarrollo y para obtener un conocimiento mayor de la materia, se debería indagar, al menos de forma teórica, en la detección de este malware.

2. NOTAS

- En relación a la entrega, es importante destacar que cada alumno, según su preferencia, podrá confeccionar los entregables tanto en castellano como en inglés, indistintamente.
- Se sugiere la elección de Markdown o LaTeX para elaborar la documentación que se haga, ya que son lenguajes adecuados cuando se requiere elaborar un documento de manera profesional y estructurada, generando un archivo pdf a partir de ese código.
- Los alumnos podrán introducir pequeñas variaciones en el enunciado de la actividad para adaptarse al campo de conocimiento que les resulte de mayor interés. Estas modificaciones deberán ser comunicadas para ser validadas previamente a la entrega.
- La suma de las calificaciones de las tareas individuales ponderan un 50% sobre la nota final del módulo.
 - 'Manejo de estructuras y funciones del kernel en un Rootkit de Windows 11': 25%
- Los alumnos podrán solicitar una o varias sesiones específicas en las que se detalle y resuelva un ejercicio similar, guiando al alumno en la entrega de dicha actividad.